

Remy remediation report

Northstar Demo - fictional AWS security review

Generated 2026-09-23 10:00 UTC | Report ee0b36c0-a39a-4db1-9d85-000000000002

Synthetic demonstration data in Prowler AWS JSON-OCSF format. Not a real scan.

3 failed findings | 1 passed | 0 manual | 4 total observations

Source and coverage notes

- FICTITIONAL EXAMPLE: Northstar Demo, all account IDs, resource names, and findings are invented. No customer or live AWS data is included.
- Local prototype: recommendation coverage and HIPAA mappings are incomplete and draft.
- An uploaded JSON file does not prove a complete HIPAA scan. No finding is marked resolved.
- Priority is provisional; full mapping, reachability and recency scoring are not yet implemented.
- Terraform is suggested guidance, not an executable deployment bundle. Review every input.
- Shared-setting review: 0 possible overlap group(s) identified. Only known template targets are compared. Missing inputs, shared dependencies, and existing Terraform ownership still require review.
- The upload contains 2 of 95 distinct check IDs in the pinned HIPAA framework. This is a membership count, not proof of scan completeness or compliance. Framework source: https://github.com/prowler-cloud/prowler/blob/73ae2eb1947a0912a05010a296f469bfa55ebe76/prowler/compliance/aws/hipaa_aws.json

Suggested Terraform requires review and adaptation. No changes have been applied. HIPAA mappings are draft; a report is not a compliance certification.

Item 1: Root account has no MFA device

Stable item ID: 8a55a1d0-40fa-5e17-9bde-afee5be5196f

Check: iam_root_mfa_enabled | Priority 65 | Guidance: manual action

Account: 123456789012 | Region: us-west-2 | Service: iam

Resource: arn:aws:iam::123456789012:root

Observed finding

Fictional example: No MFA device is registered for the fictional account root user. An authorized account owner must review and complete enrollment.

Explanation

The AWS root identity has active credentials but Prowler did not observe multi-factor authentication enabled for that identity.

Why it matters

Root credentials have unrestricted account authority. A second authentication factor reduces the chance that a stolen password alone leads to account takeover.

Suggested change

An authorized account owner should enroll an MFA device for a standalone root user, or review centralized root access for an Organizations member account and remove unneeded member-account root credentials.

Potential impact

The account owner must preserve secure recovery access and update the documented break-glass procedure. Losing both the MFA device and recovery path can delay emergency access.

HIPAA references (draft)

45 CFR 164.308(a)(3)(ii)(A): Authorization and/or supervision (HIPAA mapping - needs review)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308>

Prowler 5.42.0 framework mapping; applicability requires review. This technical result does not establish HIPAA noncompliance.

Mapping source: https://github.com/prowler-cloud/prowler/blob/73ae2eb1947a0912a05010a296f469bfa55ebe76/prowler/compliance/aws/hipaa_aws.json

45 CFR 164.312(d): Person or entity authentication (HIPAA mapping - needs review)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312>

Prowler 5.42.0 framework mapping; applicability requires review. This technical result does not establish HIPAA noncompliance.

Mapping source: https://github.com/prowler-cloud/prowler/blob/73ae2eb1947a0912a05010a296f469bfa55ebe76/prowler/compliance/aws/hipaa_aws.json

Assumptions and inputs

- The finding does not establish whether the account is standalone or uses centralized root access in AWS Organizations.
- MFA enrollment requires control of the root sign-in and a physical or virtual authenticator; no Terraform snippet can safely perform that ceremony.

Customer review and verification

1. Confirm whether this is a standalone account, an Organizations management account, or a member account with centralized root access.
2. For a root identity that remains sign-in capable, sign in through the AWS root-user flow and assign a securely controlled MFA device.
3. For an eligible member account, review centralized root access and removal of unnecessary root credentials instead of recreating persistent root access.
4. Document device custody and recovery, remove root access keys, avoid routine root use, and rerun the Prowler check.

5. AWS root-user and MFA reference:

https://docs.aws.amazon.com/IAM/latest/UserGuide/id_root-user.html#id_root-user_manage_mfa

Priority reasons: Account credential protection; Affects whole account

Item 2: Invoice archive is missing bucket-level public access blocks

Stable item ID: a00eea4b-ca66-5503-9128-3349a62288b1

Check: s3_bucket_level_public_access_block | Priority 60 | Guidance: needs context

Account: 123456789012 | Region: us-west-2 | Service: s3

Resource: arn:aws:s3:::northstar-demo-invoices

Observed finding

Fictional example: The northstar-demo-invoices bucket stores generated invoice exports. BlockPublicAcls and IgnorePublicAcls are disabled. This finding alone does not establish that any objects are publicly accessible.

Explanation

The bucket-level S3 Block Public Access check failed, so one or more of the four bucket controls is absent or disabled.

Why it matters

Those controls prevent new public ACLs or policies and suppress access granted by existing public ACLs or policies. They reduce accidental disclosure risk, but the scan result does not show whether public delivery is intentional.

Suggested change

After confirming the bucket is intended to be private, manage all four bucket-level Block Public Access flags as true. The snippet manages only the public-access-block configuration; it does not create or replace the bucket.

Potential impact

Public S3 website access can stop. CloudFront delivery can also stop if it still depends on public access rather than Origin Access Control or Origin Access Identity. RestrictPublicBuckets may also block cross-account access from a policy AWS considers public.

HIPAA references (draft)

45 CFR 164.312(a)(1): Access control (HIPAA mapping - needs review)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312>

Draft safeguard mapping for reviewer assessment; this finding alone does not establish HIPAA noncompliance.

Assumptions and inputs

- The bucket input default came from the validated observation value 'northstar-demo-invoices'.
- Bucket ownership, Terraform state ownership, website hosting, CloudFront origin design, ACLs, and bucket policy were not inferred from this observation.
- Account- and organization-level Block Public Access may impose stricter effective settings.

Suggested Terraform

Not validated against your environment. Review and adapt before applying.

```
# Suggested Terraform – review and adapt before applying.
variable "bucket_name" {
  description = "Existing general-purpose S3 bucket to protect"
  type        = string
  default     = "northstar-demo-invoices"
}

resource "aws_s3_bucket_public_access_block" "recommended" {
  bucket = var.bucket_name

  block_public_acls      = true
  block_public_policy    = true
  ignore_public_acls     = true
  restrict_public_buckets = true
}
```

PDF line wrapping is for readability. Use the ZIP for exact code text.

Customer review and verification

1. Confirm the bucket owner and whether the bucket intentionally serves a public website or another public workload.
 2. Review bucket and access-point policies, ACLs, CloudFront origin access, and effective account/organization Block Public Access before selecting flags.
 3. If this public-access-block resource is already managed by Terraform, update that resource rather than adding a duplicate.
 4. If it exists in AWS but is outside Terraform, import it only after confirming the target workspace owns it; otherwise add this resource for the existing bucket.
 5. Run terraform plan in the customer workspace, review access loss and cross-account effects, apply through the customer's process, then rerun the Prowler check.
 6. AWS behavior reference:
<https://docs.aws.amazon.com/AmazonS3/latest/userguide/access-control-block-public-access.html>
 7. Terraform resource reference:
https://registry.terraform.io/providers/hashicorp/aws/latest/docs/resources/s3_bucket_public_access_block
- Priority reasons: Potential direct data exposure; Reachability not independently verified

Item 3: Audit trail only covers one AWS region

Stable item ID: 07e555ac-09a5-532c-9adb-b66fc1ad3954

Check: cloudtrail_multi_region_enabled | Priority 46 | Guidance: needs context

Account: 123456789012 | Region: us-west-2 | Service: cloudtrail

Resource: arn:aws:cloudtrail:us-west-2:123456789012:trail/northstar-demo-audit

Observed finding

Fictional example: The northstar-demo-audit trail is configured for us-west-2 only. The fictional team also deploys services in us-east-1.

Explanation

Prowler did not observe an actively logging CloudTrail trail covering every enabled AWS Region. Event history alone is not a durable multi-Region trail.

Why it matters

A coverage or logging gap reduces the audit record available for detection and investigation of account activity.

Suggested change

Create or update a trail so logging is enabled and all enabled Regions plus global service events are covered. The snippet is intentionally minimal and requires an existing log-delivery bucket input.

Potential impact

CloudTrail and S3 storage charges may increase. A wrong bucket policy, KMS policy, home Region, or organization/account choice can prevent delivery or create a second, overlapping trail.

HIPAA references (draft)

45 CFR 164.308(a)(1)(ii)(D): Information system activity review (HIPAA mapping - needs review)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308>

Prowler 5.42.0 framework mapping; applicability requires review. This technical result does not establish HIPAA noncompliance.

Mapping source: https://github.com/prowler-cloud/prowler/blob/73ae2eb1947a0912a05010a296f469bfa55ebe76/prowler/compliance/aws/hipaa_aws.json

45 CFR 164.308(a)(3)(ii)(A): Authorization and/or supervision (HIPAA mapping - needs review)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308>

Prowler 5.42.0 framework mapping; applicability requires review. This technical result does not establish HIPAA noncompliance.

Mapping source: https://github.com/prowler-cloud/prowler/blob/73ae2eb1947a0912a05010a296f469bfa55ebe76/prowler/compliance/aws/hipaa_aws.json

45 CFR 164.308(a)(6)(ii): Response and reporting (HIPAA mapping - needs review)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308>

Prowler 5.42.0 framework mapping; applicability requires review. This technical result does not establish HIPAA noncompliance.

Mapping source: https://github.com/prowler-cloud/prowler/blob/73ae2eb1947a0912a05010a296f469bfa55ebe76/prowler/compliance/aws/hipaa_aws.json

45 CFR 164.312(b): Audit controls (HIPAA mapping - needs review)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312>

Prowler 5.42.0 framework mapping; applicability requires review. This technical result does not establish HIPAA noncompliance.

Mapping source: https://github.com/prowler-cloud/prowler/blob/73ae2eb1947a0912a05010a296f469bfa55ebe76/prowler/compliance/aws/hipaa_aws.json

45 CFR 164.312(e)(2)(i): Integrity controls (HIPAA mapping - needs review)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312>

Prowler 5.42.0 framework mapping; applicability requires review. This technical result does not establish HIPAA noncompliance.

Mapping source: https://github.com/prowler-cloud/prowler/blob/73ae2eb1947a0912a05010a296f469bfa55ebe76/prowler/compliance/aws/hipaa_aws.json

Assumptions and inputs

- The trail name default came from the validated observation value 'northstar-demo-audit'.
- The CloudTrail S3 bucket name is unknown and therefore has no generated default.
- Bucket policy, KMS encryption, log retention, event selectors, organization ownership, account scope, home Region, and Terraform state require review.
- The snippet covers management events; service data events require a separate event-selector decision and may add cost.

Suggested Terraform

Not validated against your environment. Review and adapt before applying.

```
# Suggested Terraform – review and adapt before applying.
variable "trail_name" {
  description = "Name of the CloudTrail trail to create or manage"
  type        = string
  default     = "northstar-demo-audit"
}

variable "cloudtrail_s3_bucket_name" {
  description = "Existing S3 bucket configured to accept CloudTrail log delivery"
  type        = string
}

resource "aws_cloudtrail" "recommended" {
  name                 = var.trail_name
  s3_bucket_name       = var.cloudtrail_s3_bucket_name
  enable_logging       = true
  is_multi_region_trail = true
  include_global_service_events = true
}
```

}

PDF line wrapping is for readability. Use the ZIP for exact code text.

Customer review and verification

1. Decide whether to update an existing trail, create an account trail, or use an organization trail from its management or delegated administrator account.
2. Choose the trail home Region and a protected S3 destination, then configure the required CloudTrail bucket policy and any KMS key policy before creating the trail.
3. If the trail is already managed by Terraform, update it there. If it exists outside Terraform, import it only after confirming the workspace should own the complete trail configuration.
4. Review management and data event scope, retention, encryption, duplicate-event cost, and delivery health; then plan, apply through the customer's process, and rerun the Prowler check.
5. AWS trail reference: <https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-create-and-update-a-trail-by-using-the-aws-cli-create-trail.html>
6. Terraform resource reference: <https://registry.terraform.io/providers/hashicorp/aws/latest/docs/resources/cloudtrail>

Priority reasons: Account visibility; Affects whole account